

FICBANK

Enterprise Cybersecurity Modernization

**Security Assessment Report**

Prepared By: *Caleb Tetteh*

Portfolio Edition - Version 1.0

## Table of Contents

|                                                             |    |
|-------------------------------------------------------------|----|
| 1. Executive Summary .....                                  | 4  |
| 2. Introduction / Assessment Scope .....                    | 5  |
| 2.1 Assessment Purpose .....                                | 5  |
| 2.2 Assessment Scope .....                                  | 5  |
| 2.3 Assessment Boundaries.....                              | 6  |
| 2.4 Assessment Objectives.....                              | 7  |
| 3. Assessment Methodology .....                             | 8  |
| 3.1 Assessment Methodology .....                            | 8  |
| 3.2 Assessment Framework .....                              | 9  |
| 3.3 Assessment Procedures .....                             | 10 |
| 3.4 Assessment Methods .....                                | 11 |
| 3.5 Evidence Collection and Validation.....                 | 12 |
| 3.6 Assessment Limitations .....                            | 13 |
| 4. Detailed Findings .....                                  | 13 |
| 4.1 Overview of Assessment Findings.....                    | 13 |
| 4.2 Network and Infrastructure Assessment Findings .....    | 14 |
| 4.3 Security Monitoring and Threat Detection Findings ..... | 15 |
| 4.4 Digital Forensic Investigation Findings.....            | 17 |
| 4.5 Security Control Assessment Findings .....              | 18 |

|                                                     |    |
|-----------------------------------------------------|----|
| 4.6 Overall Assessment Results .....                | 19 |
| 5. Risk Analysis and Solutions/Recommendations..... | 20 |
| 5.1 Enterprise Risk Analysis .....                  | 20 |
| 5.2 Risk Prioritization .....                       | 21 |
| 5.3 Recommended Remediation Strategy .....          | 22 |
| 5.4 Recommended Implementation Priorities.....      | 23 |
| 5.5 Expected Organizational Outcomes.....           | 24 |
| 6. Conclusion .....                                 | 25 |
| References .....                                    | 28 |

## 1. Executive Summary

FICBANK commissioned this cumulative cybersecurity assessment to evaluate the organization's overall security posture, evaluate proposed security controls and develop validation procedures, and identify opportunities to strengthen resilience against evolving cyber threats. This report consolidates the results of the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases into a comprehensive enterprise-level assessment supporting executive decision-making and future cybersecurity planning (NIST, 2020a; NIST, 2022).

The assessment included vulnerability identification, security monitoring analysis, digital forensic investigation, and evaluation of recommended technical controls. Assessment findings demonstrated that FICBANK's existing security architecture required modernization through an integrated defense-in-depth strategy (Rose et al., 2020; CISA, 2023).

The Security Modernization and Control Validation Plan recommended approximately 18 complementary security controls, including Zero Trust Architecture, network segmentation, Endpoint Detection and Response, enterprise vulnerability management, secure patch governance, and continuous monitoring. The assessment developed documented test and evaluation procedures for the recommended controls using NIST SP 800-53A assessment concepts. Because the controls were not deployed in a production environment, the engagement did not independently verify their operational effectiveness (NIST, 2022).

Overall, the assessment determined that implementing the recommended controls significantly strengthens FICBANK's confidentiality, integrity, availability, operational resilience, and long-term cybersecurity maturity while reducing enterprise risk.

## **2. Introduction / Assessment Scope**

### **2.1 Assessment Purpose**

This Security Assessment Report presents the results of a comprehensive cybersecurity assessment conducted for FICBANK to evaluate the effectiveness of the organization's existing security controls, identify risks affecting critical information systems, evaluate recommended security improvements, and support executive decision-making regarding future cybersecurity investments. The assessment consolidates the cumulative findings from the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases into a single enterprise-wide evaluation designed to provide management with an accurate understanding of FICBANK's current cybersecurity posture and the effectiveness of the proposed technical controls (NIST, 2020a; NIST, 2022).

The assessment was performed using a structured, risk-based methodology that combined vulnerability assessment, security event analysis, digital forensic investigation, technical control design, and validation planning. Rather than evaluating individual technologies independently, the assessment considered how preventive, detective, corrective, and governance controls collectively protect the confidentiality, integrity, and availability of FICBANK's information assets while supporting business continuity and regulatory expectations (NIST, 2020a).

### **2.2 Assessment Scope**

The assessment encompassed the enterprise systems, network infrastructure, security technologies, and supporting services that enable FICBANK's daily banking operations. Systems

included within the assessment scope consisted of externally accessible web services, application servers, database servers, Active Directory infrastructure, endpoint workstations, remote administration services, security monitoring platforms, backup infrastructure, and cloud-connected resources supporting critical business functions (AWS, 2023). These environments were selected because they process, transmit, or store sensitive financial and customer information and therefore represent high-value assets requiring enhanced security protections (NIST, 2020a).

The assessment also evaluated the effectiveness of enterprise security capabilities supporting identity management, network segmentation, centralized logging, endpoint protection, vulnerability management, patch governance, and continuous monitoring. Particular emphasis was placed on administrative services, privileged access mechanisms, authentication infrastructure, and systems previously identified as presenting elevated organizational risk during earlier phases of the assessment.

## **2.3 Assessment Boundaries**

The assessment was limited to activities authorized within the Security Modernization and Control Validation Plan engagement and did not include destructive testing, denial-of-service attacks, exploitation likely to interrupt production services, or unauthorized modification of organizational systems. All assessment activities were conducted using available project evidence, approved assessment procedures, and documented security data collected throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases. This approach

ensured that the assessment accurately reflected FICBANK's security posture while minimizing operational risk and preserving the integrity of production systems (NIST, 2022).

Because this engagement synthesized results from multiple assessment phases, the report incorporates findings from vulnerability assessments, security monitoring analyses, forensic investigations, and technical control evaluations to provide a comprehensive view of enterprise cybersecurity risk. Where applicable, previously identified findings were correlated with newly recommended technical controls to demonstrate how the proposed security architecture addresses documented weaknesses and improves FICBANK's overall security posture.

## **2.4 Assessment Objectives**

The primary objectives of this assessment were to:

- Evaluate the effectiveness of FICBANK's existing security controls and identify areas requiring improvement.
- Evaluate vulnerabilities, suspected indicators of compromise, and security events identified throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases.
- Assess the suitability of the recommended technical controls developed during the Security Modernization and Control Validation Plan.
- Assess whether proposed security controls collectively support defense-in-depth and Zero Trust security principles (**Rose et al., 2020; CISA, 2023**).

- Provide executive leadership with actionable recommendations that reduce enterprise cybersecurity risk while supporting operational resilience and long-term security maturity.

Collectively, these objectives establish the foundation for the assessment methodology presented in the next section and ensure that the evaluation remains aligned with recognized cybersecurity frameworks, organizational objectives, and industry best practices.

### **3. Assessment Methodology**

#### **3.1 Assessment Methodology**

This cybersecurity assessment was conducted using a structured, risk-based methodology derived from the National Institute of Standards and Technology (NIST) Risk Management Framework (RMF) and the security control assessment procedures defined in NIST Special Publication (SP) 800-53A Revision 5. The methodology was designed to provide FICBANK with an objective evaluation of its cybersecurity posture by identifying organizational risks, assessing the effectiveness of existing security controls, evaluating proposed technical safeguards and defining validation procedures, and determining the organization's ability to protect critical information assets against evolving cyber threats (NIST, 2022; NIST, 2020a).

Rather than relying on a single assessment activity, the engagement integrated multiple complementary disciplines completed throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases. These activities included external vulnerability assessment, network reconnaissance, security event monitoring, digital forensic analysis, technical control



design, and security control validation planning. Collectively, these assessment activities provided comprehensive evidence supporting the conclusions presented throughout this report while ensuring that recommendations were based on observed security conditions rather than assumptions (NIST, 2020a).

The assessment methodology emphasized repeatability, objectivity, and risk-based decision-making. Each assessment phase generated evidence that was subsequently correlated with findings from previous phases, allowing identified vulnerabilities, malicious activity, forensic artifacts, and proposed technical controls to be analyzed collectively rather than independently. This cumulative approach increased confidence in the assessment results while providing executive leadership with a comprehensive understanding of FICBANK's enterprise cybersecurity posture (NIST, 2022).

### **3.2 Assessment Framework**

The assessment followed recognized cybersecurity frameworks and industry guidance to ensure that evaluation activities reflected current security best practices and supported organizational governance objectives. Primary guidance was obtained from NIST SP 800-53 Revision 5, which defines security and privacy controls for information systems, and NIST SP 800-53A Revision 5, which establishes standardized procedures for assessing whether implemented controls are correctly configured, operating as intended, and producing the desired security outcomes (NIST, 2020a; NIST, 2022).

Zero Trust principles recommended throughout the Security Modernization and Control Validation Plan were further aligned with NIST SP 800-207 and the Cybersecurity and

Infrastructure Security Agency (CISA) Zero Trust Maturity Model Version 2.0, ensuring that identity verification, least-privilege access, continuous monitoring, and defense-in-depth principles were consistently incorporated into the proposed security architecture (Rose et al., 2020; CISA, 2023).

Collectively, these frameworks provided a common methodology for identifying organizational risks, evaluating security controls, validating recommended safeguards, and supporting continuous cybersecurity improvement throughout the assessment lifecycle.

### 3.3 Assessment Procedures

The assessment was performed in four integrated phases corresponding to the major engagement deliverables completed during the engagement.

- **The Network and Vulnerability Assessment** focused on identifying externally accessible systems through network discovery, service enumeration, and vulnerability assessment. This phase established the baseline security posture by identifying exposed administrative services, vulnerable network hosts, and weaknesses requiring additional investigation.
- **The Security Monitoring Assessment** evaluated FICBANK's detective security capabilities through analysis of web server logs, identifying reconnaissance activity, attempted exploitation, malicious HTTP requests, cloud metadata probing, Shellshock indicators, and unauthorized access attempts. These findings demonstrated active targeting of enterprise resources and provided evidence of adversary reconnaissance techniques.

- **The Incident and IOC Investigation** expanded the investigation through digital forensic analysis using packet captures, file identification techniques, and forensic evidence review. Analysis identified exploitation attempts, activity consistent with attempted malware staging, commands intended to perform remote execution, and suspected indicators of compromise while reconstructing attacker behavior and validating findings identified during earlier assessment phases.
- **The Security Modernization and Control Validation Plan** translated the cumulative assessment findings into a comprehensive security modernization strategy by recommending technical controls, developing a Security Controls Plan, and creating a structured Test and Evaluation Plan for validating recommended safeguards. These activities ensured that each recommendation directly addressed previously identified organizational risks while supporting long-term cybersecurity resilience (NIST, 2022).

### 3.4 Assessment Methods

Consistent with NIST SP 800-53A Revision 5, security controls were evaluated using three complementary assessment methods which are Examine, Interview, and Test (NIST, 2022).

- **Examine** involved reviewing system configurations, vulnerability reports, network diagrams, security policies, architecture documentation, firewall rules, forensic artifacts, and system logs to determine whether implemented controls satisfied organizational security requirements.
- **Interview** involved evaluating documented administrative procedures, operational practices, and governance processes to verify that security responsibilities, operational

procedures, and control implementation activities were consistently understood and followed by responsible personnel.

- **Test** involved validating security controls through technical assessment activities including vulnerability scanning, authentication testing, firewall rule verification, security monitoring analysis, endpoint protection validation, patch verification, backup testing, and continuous monitoring assessments.

The combination of these assessment methods provided multiple independent sources of evidence supporting the overall conclusions presented throughout this report.

### **3.5 Evidence Collection and Validation**

Assessment evidence was collected from multiple independent sources to improve confidence in the accuracy and reliability of the assessment findings. Evidence included vulnerability scan results, service enumeration data, network traffic captures, web server logs, forensic artifacts, system configuration information, technical documentation, and security monitoring data collected throughout the engagement.

Rather than evaluating individual evidence sources independently, assessment results were correlated across all four assessment phases to identify recurring patterns, validate previously observed vulnerabilities, and confirm that recommended technical controls addressed documented organizational risks. This evidence-based approach reduced the likelihood of false positives while ensuring that recommendations were supported by multiple forms of technical validation (NIST, 2022).

### **3.6 Assessment Limitations**

Although the assessment provides a comprehensive evaluation of FICBANK's cybersecurity posture, several limitations should be acknowledged. Assessment activities were limited to systems, datasets, and engagement resources authorized for evaluation and therefore did not include destructive testing, denial-of-service testing, or unrestricted penetration testing against production systems. Additionally, implementation validation was based on the proposed security architecture and documented testing procedures developed the Security Modernization and Control Validation Plan rather than a fully deployed production environment.

These limitations do not diminish the validity of the assessment. Instead, they reflect standard assessment constraints intended to balance comprehensive security evaluation with operational stability and business continuity. The methodology nevertheless provides sufficient technical evidence to support the findings, recommendations, and conclusions presented throughout this report (NIST, 2022).

## **4. Detailed Findings**

### **4.1 Overview of Assessment Findings**

The cumulative cybersecurity assessment identified several security weaknesses that collectively increase FICBANK's exposure to unauthorized access, credential compromise, malware infection, privilege escalation, lateral movement, and disruption of critical banking services. Although each assessment phase evaluated a different aspect of the organization's cybersecurity posture, the findings consistently demonstrated that multiple security deficiencies were interconnected rather than isolated. Weak identity management, inadequate internal

network segmentation, incomplete vulnerability management, and limited centralized monitoring collectively reduced the organization's ability to prevent, detect, and respond to evolving cyber threats (NIST, 2020a).

The assessment also confirmed that these risks could be substantially reduced through implementation of an integrated defense-in-depth security architecture. Consequently, the recommended technical controls presented in the Technical Controls Report were designed to address each identified weakness while improving overall organizational resilience through layered preventive, detective, corrective, and governance controls (NIST, 2020a; Rose et al., 2020).

## **4.2 Network and Infrastructure Assessment Findings**

The initial vulnerability assessment established the baseline security posture by identifying multiple publicly accessible hosts and several administrative services exposed to external networks. Services including Server Message Block (SMB), Remote Desktop Protocol (RDP), Secure Shell (SSH), Remote Procedure Call (RPC), Hyper-V management services, and the Splunk administrative interface were identified as increasing organizational exposure to unauthorized remote access and privilege escalation attacks. Because these services are commonly targeted during the early stages of cyber intrusions, their exposure significantly increased the likelihood of successful reconnaissance and exploitation (NIST, 2020a).

Although no evidence indicated that every exposed service had been successfully exploited, the assessment determined that inadequate segmentation and unrestricted administrative access substantially increased enterprise risk. Attackers obtaining access to a

single administrative service could potentially move laterally across interconnected systems, compromise privileged credentials, and access sensitive banking information. These findings directly support the recommendation to implement Zero Trust Architecture, internal firewalls, and network segmentation to reduce the attack surface and eliminate unnecessary trust relationships (Rose et al., 2020; DoD, 2022).

**Table 4-1. Summary of Network Assessment Findings**

| <b>Assessment Area</b>    | <b>Primary Finding</b>                   | <b>Organizational Risk</b> | <b>Recommended Control</b>   |
|---------------------------|------------------------------------------|----------------------------|------------------------------|
| External Services         | Multiple exposed administrative services | High                       | Zero Trust Architecture      |
| Remote Access             | RDP, SSH, SMB exposure                   | High                       | Network Segmentation         |
| Internal Network          | Limited segmentation                     | High                       | Internal Firewalls           |
| Administrative Interfaces | Excessive accessibility                  | High                       | Privileged Access Management |

### 4.3 Security Monitoring and Threat Detection Findings

Analysis of enterprise log data during the Security Monitoring Assessment demonstrated that FICBANK's internet-facing infrastructure was subjected to continuous reconnaissance and exploitation attempts. Security monitoring identified suspicious HTTP requests, directory

enumeration, malformed URL requests, cloud metadata probing, administrative interface discovery, and indicators associated with the Shellshock vulnerability. These activities indicated repeated targeting of the organization's public-facing resources and continually searched for exploitable weaknesses (NIST, 2020a).

The assessment further determined that although security logs successfully recorded many malicious events, existing monitoring capabilities lacked sufficient correlation, prioritization, and centralized visibility to rapidly distinguish isolated events from coordinated attack campaigns. As a result, analysts could experience delayed detection of sophisticated attacks involving multiple systems or attack stages. These findings support the implementation of Splunk Enterprise Security SIEM, centralized log management, behavioral analytics, and automated alert correlation to improve enterprise threat detection and incident response capabilities (NIST, 2022; CISA, 2023).

**Table 4-2. Security Monitoring Findings**

| <b>Assessment Activity</b> | <b>Observation</b>      | <b>Risk</b> | <b>Recommended Improvement</b> |
|----------------------------|-------------------------|-------------|--------------------------------|
| Web Log Analysis           | Reconnaissance activity | High        | SIEM Correlation               |
| HTTP Request Analysis      | Malicious requests      | High        | Behavioral Analytics           |
| Administrative Discovery   | Unauthorized probing    | High        | Zero Trust Access Controls     |



| Assessment Activity | Observation                    | Risk        | Recommended Improvement    |
|---------------------|--------------------------------|-------------|----------------------------|
| Event Correlation   | Limited centralized visibility | Medium–High | Splunk Enterprise Security |

#### 4.4 Digital Forensic Investigation Findings

the Incident and IOC Investigation expanded the assessment by performing forensic analysis of captured network traffic and supporting evidence. Examination of packet captures, malicious payloads, and forensic artifacts identified Shellshock-style exploitation attempts, commands intended to perform remote execution, activity consistent with attempted malware staging, and attempted compromise of enterprise systems. Correlation of multiple evidence sources enabled reconstruction of the attack sequence and determined that the suspicious activity identified during the Security Monitoring Assessment was consistent with coordinated malicious behavior rather than isolated anomalous events (NIST, 2022).

The forensic investigation also demonstrated the importance of comprehensive logging, evidence preservation, and continuous monitoring throughout the incident response lifecycle. Without centralized log collection and long-term evidence retention, reconstruction of attacker behavior would have been significantly more difficult. These findings further support the implementation of centralized SIEM capabilities, Endpoint Detection and Response (EDR), and improved incident response procedures to strengthen future investigative capabilities (NIST, 2020a).

## 4.5 Security Control Assessment Findings

the Security Modernization and Control Validation Plan translated the cumulative findings from the earlier assessment phases into a comprehensive security modernization strategy. The assessment concluded that FICBANK's existing security posture could be substantially improved through implementation of approximately 18 complementary security controls organized according to defense-in-depth principles. Recommended controls included Zero Trust Architecture, network segmentation, Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), Privileged Access Management (PAM), Splunk Enterprise Security SIEM, Endpoint Detection and Response (EDR), enterprise vulnerability management, secure patch governance, encryption, backup protection, and continuous monitoring (NIST, 2020a; Rose et al., 2020).

Validation planning performed during the Security Modernization and Control Validation Plan further determined that each recommended control could be assessed using the Examine, Interview, and Test methodology defined in NIST SP 800-53A Revision 5, providing objective evidence that implemented controls are correctly configured, operating as intended, and effectively reducing organizational risk (NIST, 2022).

**Table 4-3. Correlation of Assessment Findings and Recommended Controls**

| <b>Assessment Finding</b>       | <b>Technical Control</b> | <b>Expected Risk Reduction</b> |
|---------------------------------|--------------------------|--------------------------------|
| Exposed Administrative Services | Zero Trust Architecture  | High                           |

| <b>Assessment Finding</b> | <b>Technical Control</b>         | <b>Expected Risk Reduction</b> |
|---------------------------|----------------------------------|--------------------------------|
| Flat Network Architecture | Network Segmentation             | High                           |
| Weak Authentication       | MFA / RBAC / PAM                 | High                           |
| Limited Threat Visibility | Splunk Enterprise Security       | High                           |
| Endpoint Exposure         | Endpoint Detection & Response    | High                           |
| Patch Management Gaps     | Vulnerability Management Program | High                           |

#### 4.6 Overall Assessment Results

Correlation of evidence collected throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases demonstrates that the identified vulnerabilities, malicious activity indicators, forensic evidence, and security control recommendations collectively describe a consistent cybersecurity risk profile. Rather than representing isolated technical weaknesses, the assessment findings reveal systemic gaps in identity governance, network architecture, vulnerability management, and enterprise security monitoring that require coordinated remediation (NIST, 2020a).

The proposed security modernization strategy directly addresses each of these findings through an integrated defense-in-depth architecture supported by Zero Trust principles, continuous monitoring, structured vulnerability management, and ongoing security control

validation planning planning. Consequently, the assessment concludes that implementation of the recommended controls will significantly reduce organizational risk while improving FICBANK's ability to prevent, detect, respond to, and recover from cybersecurity incidents (Rose et al., 2020; NIST, 2022).

## **5. Risk Analysis and Solutions/Recommendations**

### **5.1 Enterprise Risk Analysis**

The cumulative assessment determined that FICBANK's cybersecurity posture presents an overall “High” level of organizational risk. This determination is based on the correlation of evidence collected throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases, including externally exposed administrative services, inadequate internal network segmentation, weaknesses in identity and access management, incomplete vulnerability management processes, and evidence of reconnaissance and exploitation attempts targeting internet-facing systems. While no evidence indicated a sustained compromise of critical banking operations, the assessment confirmed that these weaknesses collectively increase the likelihood of unauthorized access, credential theft, privilege escalation, lateral movement, and disruption of essential business services (NIST, 2020a).

The assessment further determined that these risks are systemic rather than isolated. Individual vulnerabilities identified during the engagement reinforce one another and reduce the effectiveness of existing security controls when considered collectively. For example, exposed administrative services combined with insufficient network segmentation increase opportunities

for attackers to establish initial access and move laterally through the enterprise. Similarly, limited centralized monitoring and incomplete identity governance reduce the organization's ability to rapidly detect, investigate, and contain malicious activity. Consequently, isolated remediation efforts would provide only limited improvements. A coordinated, defense-in-depth strategy is necessary to achieve sustainable risk reduction and long-term cybersecurity resilience (Rose et al., 2020; CISA, 2023).

## 5.2 Risk Prioritization

Risk prioritization was performed by considering the likelihood of exploitation, potential operational impact, and the sensitivity of affected systems. Findings with the greatest potential to disrupt banking operations or compromise customer information were assigned as the highest remediation priority. This approach enables FICBANK to allocate cybersecurity resources efficiently while addressing the most significant enterprise risks first (NIST, 2020a).

**Table 5-1. Enterprise Risk Prioritization**

| <b>Risk Area</b>                  | <b>Overall Risk</b> | <b>Business Impact</b>     | <b>Priority</b> |
|-----------------------------------|---------------------|----------------------------|-----------------|
| Exposed Administrative Services   | High                | Unauthorized remote access | Immediate       |
| Weak Identity and Access Controls | High                | Credential compromise      | Immediate       |
| Limited Network Segmentation      | High                | Lateral movement           | Immediate       |

| <b>Risk Area</b>                    | <b>Overall Risk</b> | <b>Business Impact</b>                | <b>Priority</b> |
|-------------------------------------|---------------------|---------------------------------------|-----------------|
| Incomplete Vulnerability Management | High                | Exploitation of known vulnerabilities | High            |
| Limited Security Monitoring         | Medium to High      | Delayed threat detection              | High            |
| Endpoint Security Gaps              | Medium-High         | Malware and ransomware                | High            |

As shown in *Table 5-1*, the highest-priority risks are closely interconnected. Addressing identity security without strengthening network segmentation, or improving monitoring without resolving vulnerability management deficiencies, would leave significant residual risk. Therefore, remediation activities should be implemented as an integrated cybersecurity modernization program rather than as independent technical projects.

### **5.3 Recommended Remediation Strategy**

Based on the cumulative assessment findings, FICBANK should adopt a phased remediation strategy that emphasizes coordinated implementation of complementary security controls. Rather than replacing existing technologies, the organization should enhance its current security architecture through layered preventive, detective, corrective, and governance controls that collectively reduce enterprise risk (NIST, 2020a).

The highest implementation priority should be given to the recommendations presented in the accompanying Technical Controls Report, including:

- Adoption of a Zero Trust Architecture to eliminate implicit trust and continuously verify users, devices, and workloads (Rose et al., 2020).
- Deployment of network segmentation and internal firewalls to restrict lateral movement between critical systems (DoD, 2022).
- Strengthening Identity and Access Management through Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), and Privileged Access Management (PAM) (NIST, 2020a).
- Expansion of Splunk Enterprise Security SIEM capabilities to improve centralized monitoring, event correlation, and incident response (NIST, 2022).
- Enterprise-wide implementation of Endpoint Detection and Response (EDR) to strengthen endpoint visibility and automated threat containment (NIST, 2020a).
- Establishment of a mature Vulnerability Management and Patch Governance Program supported by authenticated vulnerability scanning, risk-based remediation, secure configuration management, and continuous validation (NIST, 2022).

Collectively, these recommendations address the root causes of the identified findings while supporting long-term organizational resilience.

## **5.4 Recommended Implementation Priorities**

Because enterprise-wide cybersecurity modernization requires careful planning, implementation should occur in manageable phases that reduce operational disruption while delivering measurable security improvements.

**Table 5-2. Recommended Implementation Roadmap**

| <b>Timeframe</b>      | <b>Priority Activities</b>                                                                                                                                          |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>0 to 30 Days</b>   | Secure exposed administrative services, implement MFA for privileged accounts, begin authenticated vulnerability scanning, establish emergency patching procedures. |
| <b>30 to 90 Days</b>  | Deploy internal firewalls, implement network segmentation, expand centralized logging and SIEM correlation, deploy EDR to high-value systems.                       |
| <b>3 to 6 Months</b>  | Complete RBAC and PAM implementation, automate vulnerability management workflows, strengthen backup protection, conduct security awareness training.               |
| <b>6 to 12 Months</b> | Validate all implemented controls, perform independent security assessments, refine continuous monitoring processes, and mature Zero Trust governance.              |

This phased roadmap allows FICBANK to reduce immediate risk while establishing a sustainable cybersecurity program aligned with organizational objectives and available resources (NIST, 2022).

### **5.5 Expected Organizational Outcomes**

Implementation of the recommended remediation strategy will significantly strengthen FICBANK's cybersecurity posture by reducing the likelihood and potential impact of cyberattacks targeting enterprise systems. The recommended controls improve the confidentiality, integrity, and availability of organizational information assets while



strengthening identity protection, limiting lateral movement, improving threat detection, and reducing exposure to known vulnerabilities (NIST, 2020a; Rose et al., 2020).

Beyond improving technical security, the proposed strategy supports executive governance by providing measurable security objectives, repeatable assessment procedures, and continuous monitoring capabilities that enable leadership to evaluate cybersecurity performance over time. The combination of structured governance, ongoing validation, and risk-based decision-making establishes a sustainable cybersecurity program capable of adapting to changing technologies, evolving threats, and future regulatory expectations (NIST, 2022; CISA, 2023).

## **6. Conclusion**

This Security Assessment Report provides a comprehensive evaluation of FICBANK's cybersecurity posture by consolidating the results of vulnerability assessment, security monitoring analysis, digital forensic investigation, and security control planning performed throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, Incident and IOC Investigation, and Security Modernization and Control Validation Plan phases. Collectively, these assessment activities provided objective evidence of the organization's current security strengths, identified critical areas requiring improvement, and established a structured foundation for future cybersecurity modernization (NIST, 2020a; NIST, 2022).

The assessment confirmed that FICBANK's overall cybersecurity risk posture is “High”, primarily due to exposed administrative services, insufficient internal network segmentation, weaknesses in identity and access management, incomplete vulnerability management processes, and limited centralized monitoring capabilities. Although the assessment identified no evidence

of a sustained compromise of critical banking operations, the combination of these deficiencies increases the organization's exposure to unauthorized access, credential theft, malware infection, privilege escalation, and lateral movement. These findings demonstrate that enterprise cybersecurity risks should not be addressed through isolated technology upgrades but through an integrated, defense-in-depth security strategy supported by continuous governance and ongoing assessment (NIST, 2020a; Rose et al., 2020).

The recommended security modernization strategy directly addresses each significant finding identified during the assessment. Adoption of a Zero Trust Architecture, strengthened Identity and Access Management, network segmentation, Splunk Enterprise Security SIEM, Endpoint Detection and Response, enterprise vulnerability management, secure patch governance, and continuous monitoring establishes a coordinated security architecture capable of reducing enterprise risk while improving the confidentiality, integrity, and availability of FICBANK's information assets (Rose et al., 2020; CISA, 2023).

Equally important, the assessment emphasizes that effective cybersecurity requires continuous validation rather than one-time implementation. The accompanying Test and Evaluation Plan provides a structured methodology for assessing recommended controls using the Examine, Interview, and Test assessment methods defined in NIST Special Publication 800-53A Revision 5, enabling FICBANK to verify that implemented controls operate as intended and continue supporting organizational objectives as technologies and cyber threats evolve (NIST, 2022).

Overall, the assessment concludes that implementation of the recommended technical controls will significantly strengthen FICBANK's cybersecurity posture while improving operational resilience, risk management, and long-term organizational security maturity. By

adopting a risk-based cybersecurity program founded on continuous monitoring, structured governance, periodic assessment, and ongoing improvement, FICBANK will be better positioned to protect critical banking operations, safeguard customer information, and respond effectively to future cybersecurity challenges (NIST, 2020a; NIST, 2022).

## References

Amazon Web Services. (2023). *Patch management in AWS*.

Cybersecurity and Infrastructure Security Agency. (2023). *Zero Trust maturity model* (Version 2.0).

Department of Defense. (2022). *Department of Defense Zero Trust Reference Architecture* (Version 2.0).

National Institute of Standards and Technology. (2020a). *Security and privacy controls for information systems and organizations* (Special Publication 800-53, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2022). *Assessing security and privacy controls in information systems and organizations* (Special Publication 800-53A, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53Ar5>

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust architecture* (Special Publication 800-207). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207>